

****22.08.2024****

****Sanctions for GDPR Violations****

The National Authority for the Supervision of Personal Data Processing completed two investigations in 2024 concerning two operators.

The investigations were initiated following notifications of data security breaches, pursuant to the provisions of Article 33 of Regulation (EU) 2016/679, which were submitted by Kruk România SRL and Kaufland România SCS.

As such, it was found that:

1. The operator Kruk România SRL violated the provisions of Article 32 paragraph (1) letter b) in conjunction with Article 32 paragraph (2) of Regulation (EU) 2016/679 and was sanctioned with an administrative fine of 14,922.3 RON (equivalent to 3,000 EURO).
2. The operator Kaufland România SCS violated the provisions of Article 32 paragraph (1) letter b) and Article 32 paragraphs (2) and (4) of Regulation (EU) 2016/679 and was sanctioned with 3 fines totaling 34,839 RON (equivalent to 7,000 EURO).

1. In the course of the investigation, the National Authority for the Supervision of Personal Data Processing found that, as a data processor for the operator, Kruk România SRL erroneously transmitted a series of notifications regarding the assignment of receivables to several recipients and notifications regarding the possibility of entering into a payment commitment with debtors by performing inappropriate manual processing operations on the database transmitted by a contractual partner under an assignment of receivables contract.

This situation led to the unauthorized disclosure and/or unauthorized access to personal data (such as names, surnames, addresses, contract dates and numbers, amounts owed, original creditor, creditor, and receivables administrator) contained in the respective documents.

From the checks carried out, it resulted that the data processor, Kruk România SRL, did not implement appropriate technical and organizational measures to ensure a level of security commensurate with the risk of processing, including the ability to ensure the confidentiality, integrity, availability, and continuous resilience of processing systems and services.

At the same time, the operator was also subjected to the corrective measure of reviewing and updating the technical and organizational measures implemented as a result of the risk assessment regarding the rights and freedoms of individuals, including work procedures related to the protection of personal data, in order to ensure the protection of processed (manual) data against unauthorized processing, loss, destruction, or accidental deterioration, and measures regarding the training of persons acting under its authority concerning their obligations under the provisions of Regulation (EU) 2016/679, including regarding the risks and consequences involved in unauthorized disclosure/unauthorized access/loss of personal data.

2. In the investigation conducted at the operator Kaufland România SCS, following the transmission of several notifications of personal data security breaches, violations of data processing were found in the following situations:

Thus, a first situation concerned the recording with a mobile phone by the security agents of the operator of images captured by the store's surveillance cameras regarding an incident that occurred on the premises. This situation led to unauthorized access and disclosure of these images to one of the data subjects, at their request.

During the investigation, it was found that the operator did not implement appropriate technical and organizational measures to ensure that any natural person acting under the authority of the operator or the person authorized by the operator who has access to personal data processes them only at the request of the operator in order to ensure a level of security commensurate with the risk of processing generated, in particular, accidentally or illegally, by the destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or processed in another way, thus violating the provisions of Article 32 paragraph (1) letter b) and paragraph (4) of Regulation (EU) 2016/679.

For this violation, the operator was sanctioned with a fine of 9,954 RON (equivalent to 2,000 EURO).

A second situation concerns the photographing, with a mobile phone, of images from the operator's monitoring room. Thus, a customer reported to the operator's security agent the theft of their phone from their bag and requested the video images of the incident. The security agent allowed the customer access to the monitoring room. The customer photographed the images of the alleged person (the data subject) and subsequently posted them on their Facebook account. The situation created led to unauthorized access by a third party and unauthorized disclosure online of the image of a customer. This fact may lead, in particular, to physical, material, or moral damages to the affected natural person, such as the loss of control over their personal data or the loss of confidentiality of personal data protected by professional secrecy or another significant disadvantage of an economic or social nature to the affected natural person.

During the investigation, it was found that the operator did not take measures to ensure that any natural person acting under the authority of the operator and having access to personal data processes them only at the request of the operator and did not implement appropriate technical and organizational measures.

In order to ensure an appropriate level of security corresponding to the risk of processing, including the ability to ensure the confidentiality and integrity of processing systems and services, thus violating the provisions of Article 32 paragraph (1) letter b) and paragraphs (2) and (4) of Regulation (EU) 2016/679. For this violation, the operator was fined in the amount of 14,931 lei (equivalent to 3,000 EURO).

The third situation refers to the loss of data confidentiality, as an employee of Kaufland involved in the recruitment process of a candidate (the data subject) mistakenly sent an email to another person, who owns an internet domain. This situation led to unauthorized access and unauthorized disclosure to the domain holder of personal data (such as the name, surname, and location of the store where the application was made) of a person who applied for a job within the operator.

As a result of the investigation, the National Authority for the Supervision of Personal Data Processing found that the operator had not implemented appropriate technical and organizational measures to ensure that any natural person acting under the authority of the operator or of the person authorized by the operator who has access to personal data processes it only at the request of the operator and in order to ensure an appropriate level of security corresponding to the risk of processing generated, in particular, accidentally or illegally, by the destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or processed in any other way, thus violating Article 32 paragraph (1) letter b), paragraphs (2) and (4) of Regulation (EU) 2016/679. For this violation, the operator was fined in the amount of 9,954 lei (equivalent to 2,000 EURO).

Under Article 58 paragraph (2) letter d) of Regulation (EU) 2016/679, the operator was ordered to implement the corrective measure of appointing one or more persons at the level of the operator/person authorized by the operator to monitor the processing activities of personal data of individuals acting under the authority of the operator/person authorized by the operator, in accordance with working procedures, to avoid similar security incidents.

We mention that the operators have paid the imposed fines.

Legal and Communication Department
N.A.S.P.D.C.P